

System Hardening And Business Rules

Table of Contents

Contratos de negocio, seguridad y operación

Principios de dirección

Roles y alcance útil

Contratos de negocio

Prospecto a estudiante

Grupos, matrícula y cupo

Agenda y ciclo de sesión

Asistencia de estudiantes

Justificaciones

Becas y promoción

Jornada y pago docente

Cartera y libro financiero

Reportes gerenciales y calidad

Seguridad aplicada

Auditoría y trazabilidad

Runbook de base de datos y primer acceso

Preparación

Migración

Bootstrap del primer Admin

Monitoreo y rollback

Acciones externas obligatorias pendientes

Cambios que requieren migración dedicada

Contratos de negocio, seguridad y operación

Este documento es la referencia operativa del sistema American Latin Class. Describe qué debe impedir el sistema, qué evidencia conserva y cómo desplegarlo sin saltarse controles. Las migraciones SQL y el código siguen siendo la fuente ejecutable; cualquier cambio de regla debe actualizar implementación, pruebas, métricas y este documento en el mismo cambio.

Principios de dirección

1. La asistencia, el dinero y la nómina son hechos auditables: no se borran ni reescriben silenciosamente.
2. La sede, el nivel, la matrícula y la asignación docente determinan el acceso y la validez académica; el rol por sí solo no basta.
3. Un reporte de gestión debe declarar periodo, fecha de cálculo, fecha de corte y fórmula. Un número sin contexto no es control.
4. Los estados terminales conservan historia. Las correcciones posteriores usan un nuevo hecho enlazado o una versión con motivo y actor.
5. Seguridad y auditoría forman parte de la transacción de negocio, no son tareas manuales posteriores.

Roles y alcance útil

Rol	Trabajo habilitado	Límite obligatorio
Visitor	Consultar landing/catálogo público y enviar solicitud.	Sin acceso a datos privados.
Student	Ver perfil, grupos, clases, asistencia, justificaciones, pagos y eventos propios; justificar ausencia.	Nunca ve otro estudiante ni modifica hechos académicos/financieros.
Teacher	Ver grupos/sesiones asignados, operar roster y su propia jornada.	No ve grupos ajenos, no cambia notas finales sin autoridad de director ni administra tarifas.
BranchDirector	Operar estudiantes, docentes, matrículas, agenda, leads, cobros y revisiones de sedes asignadas.	Sin datos de otra sede, catálogos globales, roles globales, reversos pagados ni tarifas docentes.

Rol	Trabajo habilitado	Límite obligatorio
GeneralDirector	Control global, reportes, auditoría, estructura académica y reversos.	No puede conceder Admin/GeneralDirector; no reemplaza el control técnico del Admin.
Admin	Administración global, identidades, roles, sedes, acceso y operación completa.	También queda sujeto a integridad, auditoría y estados terminales.

Contratos de negocio

Prospecto a estudiante

- La solicitud pública normaliza email/nombre, exige sede activa si fue seleccionada y aplica rate limiting.
- Para un mismo email y sede, no se abre otra oportunidad activa (`pending` , `contacted` , `trial_scheduled`) dentro de 24 horas.
- Transiciones permitidas:
 - `pending` → `contacted` | `lost`
 - `contacted` → `trial_scheduled` | `enrolled` | `lost`
 - `trial_scheduled` → `contacted` | `enrolled` | `lost`
 - `enrolled` y `lost` son terminales.
- `trial_scheduled` exige fecha futura; `lost` exige motivo de al menos cinco caracteres.
- `enrolled` exige un perfil Student activo y, cuando la solicitud tiene sede, debe coincidir. Marcar un lead no crea una matrícula académica implícita.
- Cada cambio conserva actor, fecha, estado anterior/nuevo, seguimiento, conversión y notas en auditoría.

Indicadores: volumen por etapa, conversión `enrolled / total` , seguimientos vencidos y tiempo de ciclo (este último puede añadirse sin cambiar estados).

Grupos, matrícula y cupo

- El grupo pertenece a una sede activa, un nivel B1/B2 y tiene capacidad entera entre 1 y 200.
- Docente asignado y grupo deben compartir sede y estar activos. Si `teacher_styles` declara especialidades, el estilo del grupo debe estar entre ellas; no declarar especialidades no bloquea la asignación.
- BranchDirector no fija ni cambia tarifa docente. Al crear desde sede se fuerza la tarifa estándar 12,50; GeneralDirector/Admin son los únicos que administran la tarifa vigente.

- La matrícula exige mismo nivel y sede entre estudiante/grupo. Para ocupar un cupo, ambos deben estar activos.
- `active` y `trial` consumen cupo. Si no hay disponibilidad, la operación queda `waitlisted` dentro de la misma transacción; nunca sobreviene silenciosamente.
- Estados y transiciones:
 - `active` → `frozen` | `withdrawn` | `completed`
 - `trial` → `active` | `waitlisted` | `withdrawn` | `completed`
 - `waitlisted` → `active` | `trial` | `withdrawn`
 - `frozen` → `active` | `withdrawn`
 - `withdrawn` y `completed` son terminales.
- Retiro requiere motivo. `withdrawn` y `completed` cierran ese episodio. La reinscripción crea una fila nueva solo cuando todos los episodios anteriores son terminales y tienen `endsAt`; no puede solaparse con ellos y cualquier `active`, `trial`, `waitlisted` o `frozen` bloquea con conflicto.
- Fechas de inicio/fin y linaje de episodios conservan el roster histórico; no se reduce capacidad por debajo de ocupación vigente.
- Roster, acceso y métricas seleccionan el episodio cuyo intervalo cubre la fecha de cada sesión, no simplemente la matrícula más reciente.

Indicadores: ocupación `matrículas active/trial vigentes / capacidad activa`, cupos disponibles, lista de espera, retiros y conversión de prueba a activa.

Agenda y ciclo de sesión

- Una sesión nueva comienza `scheduled`, tiene fin posterior al inicio y duración máxima de seis horas.
- No puede solaparse con una sesión no cancelada del mismo grupo ni del docente asignado.
- No se agenda sobre grupo inactivo. Una sesión futura no puede marcarse completada antes de terminar.
- Cancelar exige motivo y registra actor/fecha. Completar exige asistencia `finalized` y metadatos coherentes de actor/fecha. `completed` y `cancelled` son inmutables.
- El borrador de asistencia puede guardarse después del inicio; finalizar o corregir espera hasta `endsAt`, completa la sesión y registra actor/fecha.

Asistencia de estudiantes

- El roster se deriva de matrículas que cubrían la fecha de la sesión; la lista de espera no participa. Después de finalizar, el roster histórico no desaparece por cambios actuales.
- Estados físicos válidos: `present`, `late`, `absent`. `justified` no es un cuarto hecho físico: la justificación vive en su propio flujo.

- El docente/director puede guardar borrador. Para finalizar debe enviar exactamente un registro por cada integrante del roster y ninguno adicional.
- La finalización es idempotente si no cambia datos, no vuelve a borrador y completa la sesión.
- Corregir una asistencia final requiere BranchDirector/GeneralDirector/Admin, motivo de al menos cinco caracteres, nueva versión, actor y antes/después. Si una ausencia cambia, justificaciones pendientes/aprobadas incompatibles se rechazan automáticamente con explicación.
- Sesiones canceladas, futuras, grupos inactivos, estudiantes no matriculados o lotes duplicados son rechazados.

Métricas:

- Asistencia física bruta = $(\text{present} + \text{late}) / \text{sesiones finalizadas del roster}$.
- Una ausencia aprobada sigue apareciendo en ausencia bruta, pero se excluye del denominador ajustado.
- Asistencia ajustada = $(\text{present} + \text{late}) / (\text{sesiones finalizadas} - \text{ausencias aprobadas})$.
- Puntualidad = $\text{present} / (\text{present} + \text{late})$.

Justificaciones

- Solo se justifica un registro propio/visible que continúe `absent`; la razón es obligatoria y la evidencia opcional debe usar HTTPS.
- Estado: `pending → approved | rejected`; solo directores con alcance pueden revisar.
- Aprobar no altera el estado físico. La decisión, revisor, fecha y notas permanecen auditables.

Becas y promoción

- Solo cuentan sesiones con asistencia finalizada y no canceladas; una decisión no se basa en borradores.
- Regla de beca activa por defecto: 90% de asistencia ajustada, periodo de dos meses y mínimo ocho sesiones contabilizadas. El estudiante debe estar activo.
- Becas no se aprueban automáticamente: teoría y práctica deben ser al menos 70 y el director elige 25/50/75/100%. La ventana evaluada se persiste: puede existir otro ciclo posterior, pero no dos aprobaciones para estudiante y misma ventana.
- Promoción: estudiante activo B1, al menos 85% ajustado y ocho sesiones contabilizadas; consistencia, teoría y práctica deben ser al menos 70.
- Una promoción aprobada actualiza B1→B2 y guarda evaluación/auditoría en la misma transacción serializable. No se permite una segunda aprobación de esa transición; reprobar conserva evidencia sin cambiar el nivel.

Jornada y pago docente

- Check-in requiere docente activo, sesión `scheduled`, grupo asignado y ventana desde 60 minutos antes hasta 60 minutos después de la clase.
- No se permite más de un turno abierto ni duplicar docente/sesión.
- Checkout no puede preceder al check-in y no se repite.
- Minutos pagables = mínimo entre tiempo real, duración programada + 30 minutos y 720 minutos. Se guarda tarifa por hora y minutos como snapshot histórico.
- El reporte de pago usa únicamente turnos cerrados en el periodo y devuelve desglose por turno; un cambio de tarifa no modifica periodos pasados.

Cartera y libro financiero

- El cargo exige estudiante activo, monto positivo, concepto normalizado y periodo calendario `YYYY-MM`; la sede contable se deriva del estudiante al crearlo y no cambia silenciosamente si el estudiante se traslada después.
- No puede existir otro cargo no cancelado para estudiante + periodo + concepto normalizado.
- `paid` exige fecha de pago (se asigna al cobrar si falta) y la fecha no puede estar en el futuro; registros no pagados no llevan `paidAt`. Vencimiento deriva `overdue` sin reescribir historia innecesariamente.
- Cambiar monto/concepto/periodo o cancelar exige motivo. Un cargo no se transfiere a otro estudiante.
- `paid` y `cancelled` son inmutables. Un pago asentado solo se corrige con un movimiento negativo enlazado, una vez, por GeneralDirector/Admin y con razón. El original permanece.
- Todo alta, corrección, cobro, cancelación y reverso comparte transacción con auditoría.

Métricas: recaudo bruto positivo, monto reversado, recaudo neto, mensualidad/otros/show, cartera pendiente/vencida y aging actual/1–30/31–60/61–90/90+ días. Para cortes históricos, obligaciones se incluyen si ya existían al `asOf`, aunque el filtro `from` sea posterior.

Reportes gerenciales y calidad

Los endpoints general, resumen de sedes y detalle aceptan `from` / `to` ISO con máximo 1095 días y zona `America/Bogota`:

- `generatedAt`: cuándo se calculó la respuesta.
- `asOf`: fecha efectiva de corte; usa la más temprana entre `to` y la generación para no proyectar estados futuros.
- Tendencias: seis meses de ingreso neto, asistencia ajustada, puntualidad y volumen.
- Distribuciones: asistencia física y estado de cartera.

- Funnel comercial y conversión.
- Ocupación, capacidad y lista de espera por sede.

`asOf` controla reconocimiento, aging, ocupación y corte temporal con la información disponible al generar. No es por sí solo un cierre contable inmutable: decisiones registradas después (por ejemplo una justificación tardía) pueden cambiar una regeneración histórica. Un cierre formal debe exportarse, aprobarse y conservarse con identificación/hash o implementarse como snapshot versionado.

Alertas automáticas disponibles: pago cobrado sin fecha, pago/sede inconsistente, check-in abierto > 12h, sesión pasada sin finalizar, cargo activo duplicado, jornada docente duplicada, pago huérfano, reverso huérfano, matrícula con sede/nivel/referencia inconsistente, grupo sobre capacidad y seguimiento comercial vencido. Una alerta no repara datos; abre una tarea operativa que debe quedar resuelta con el flujo auditado apropiado.

Seguridad aplicada

- Staging/producción fallan cerrado sin `DATABASE_URL`, secreto de sesión fuerte o configuración segura. Memoria requiere test o opt-in explícito de desarrollo.
- El servidor y Vite se enlazan por defecto a `127.0.0.1` en desarrollo; staging/producción usan `0.0.0.0` detrás del proxy. `HOST` no acepta URL ni ruta.
- JWT declara issuer/audience/sesión/usuario y se valida contra sesión persistida, vigencia, revocación y usuario activo. Cambiar contraseña revoca sesiones anteriores y rota la actual.
- Cookies de producción son Secure/HttpOnly/SameSite; escrituras autenticadas por cookie usan CSRF double-submit. Los clientes Bearer no dependen de cookie.
- CORS acepta orígenes exactos, HTTPS puede forzarse detrás de proxy confiable, Helmet/CSP endurece cabeceras, JSON se limita a 100 KiB y autenticación/solicitudes públicas tienen rate limit.
- Cada respuesta lleva `X-Request-Id`. Errores 500 no exponen stack, SQL, host ni secretos.
- Node y FastAPI comparten política de sesión/autorización. Analítica no puede arrancar con bypass de autenticación fuera de tests.
- La foto de perfil acepta en navegador un PNG/JPEG/WebP original de hasta 8 MB, lo recorta cuadrado y comprime localmente a WebP/JPEG con data URL ≤90.000 caracteres, por debajo del JSON global de 102.400 bytes. También admite URL HTTPS; evidencias externas requieren HTTPS.
- Nginx debe responder 404 para `/db-admin/`. PostgreSQL/RDS nunca se publica a Internet.

Auditoría y trazabilidad

El registro mínimo es `actorUserId`, acción, entidad, id, metadata sanitizada y fecha. El contexto acotado de la solicitud añade request ID, método/ruta sin query, IP y user-agent; no incluye cuerpo, token ni cookie. Las escrituras críticas crean dato y audit log en la misma transacción. Entre las acciones relevantes están autenticación/cambio de contraseña, gestión de cuenta/rol/sede, lead, matrícula, borrador/finalización/corrección de asistencia, justificación, ciclo de sesión, turno docente, evaluación, cargo y reverso.

`GET /api/v1/audit-logs` es exclusivo de GeneralDirector/Admin y filtra por acción, entidad, actor y fechas; pagina 1–200 registros mediante `limit` / `offset` y devuelve contadores en cabeceras. El log no debe almacenar contraseñas, tokens, cookies ni secretos.

Runbook de base de datos y primer acceso

Preparación

1. Inyectar secretos fuera de Git y comprobar que `DATABASE_URL` apunta al entorno correcto.
2. Crear/verificar snapshot o PITR antes de tocar un entorno con datos.
3. En `06Code`, ejecutar `npm ci`, `npm run db:generate`, pruebas y build.

Migración

```
cd 06Code
npm run db:migrate:status
npm run db:migrate
npm run db:migrate:status
npm run db:smoke:prisma
npm run db:smoke:operational
```

El runner toma advisory lock `30716`, comprueba checksum y ejecuta cada archivo pendiente en una transacción. No modificar un archivo aplicado, no ejecutar migraciones a mano fuera del ledger y no usar schema push.

Bootstrap del primer Admin

Definir temporalmente `BOOTSTRAP_ADMIN_CONFIRM=CREATE_INITIAL_ADMIN`, email, nombre y contraseña fuerte (14–120 con mayúscula, minúscula, número y símbolo), luego ejecutar:

```
npm run db:bootstrap-admin
```


El comando se niega si ya existe Admin activo, marca cambio obligatorio y audita sin imprimir contraseña. Iniciar sesión, cambiarla y eliminar inmediatamente las cuatro variables. Los seeds demo están prohibidos en producción.

Monitoreo y rollback

- ALB/Nginx usa `GET /api/v1/health/live` para liveness y `GET /api/v1/health/ready` para readiness. Ready hace una lectura a persistencia y responde `503` sanitizado cuando no está disponible.
- Monitorear 5xx, latencia p95/p99, 401/403/409/422 por ruta, readiness, conexiones RDS, CPU/memoria, rate-limit, colas de seguimiento, sesiones sin finalizar y alertas de calidad.
- Ante una migración fallida, el archivo revierte automáticamente. No editar checksum ni marcarla manualmente; diagnosticar, corregir con una nueva revisión antes de reintentar.
- Si una migración aplicada produjo daño lógico, detener escrituras, preservar logs, restaurar snapshot/PITR en instancia nueva, reconciliar y cambiar tráfico. Un `git revert` no revierte datos.

Acciones externas obligatorias pendientes

Sanitizar archivos del repositorio **no rota ni revoca credenciales externas**. Antes de considerar seguro un entorno existente, una persona con autoridad debe completar y documentar:

1. Rotar/revocar cualquier credencial que alguna vez se haya expuesto: usuario/contraseña RDS, IAM access keys, secretos de sesión, cuentas de prueba/reales, tokens y configuración OAuth afectada. Actualizar Secrets Manager/Parameter Store y reiniciar servicios de forma controlada.
2. Tras rotar `SESSION_SECRET` o credenciales de cuenta, invalidar sesiones activas y verificar que tokens/cookies anteriores ya no funcionan.
3. Confirmar en infraestructura desplegada —no solo en el archivo Nginx local— que `/db-admin/` y cualquier Adminer/pgAdmin no están instalados ni accesibles; restringir 5432 a security groups de aplicación.
4. Revisar CloudTrail, logs de ALB/Nginx/aplicación, RDS y proveedor OAuth desde la fecha de posible exposición para detectar accesos anómalos; preservar evidencia y escalar incidentes si corresponde.
5. Verificar dominio/ACM, orígenes OAuth/CORS exactos, HSTS, backups/PITR, alarmas y pruebas de restauración. Retirar DNS/IP/usuarios temporales.

Estas acciones dependen de AWS, Google y propietarios de cuentas; este repositorio no demuestra que ya hayan sido ejecutadas.

Cambios que requieren migración dedicada

Actualizaciones mayores de Prisma, Express, React, Vite, Zod, dotenv o rate limiter se mantienen fuera de una actualización rutinaria. Cada una requiere rama propia, guía de migración, pruebas de seguridad/contratos, prueba PostgreSQL real, build y QA visual antes de producción.